

# Esercizio: Password Cracking su DVWA

Argomento: Password Cracking | Recupero delle Password in Chiaro

## 1. Obiettivo dell'Esercizio

In questo esercizio ho recuperato le password hashate presenti nel database dell'applicazione DVWA (Damn Vulnerable Web Application) e ho eseguito sessioni di cracking per ottenerne la versione in chiaro, utilizzando gli strumenti studiati durante la lezione teorica.

Le fasi svolte sono state le seguenti:

- Accesso al database MariaDB del sistema DVWA
- Estrazione degli hash MD5 dalla tabella users
- Esecuzione del cracking con John the Ripper e la wordlist rockyou.txt
- Verifica e documentazione delle password recuperate in chiaro

## 2. Accesso al Database DVWA

Ho avviato il servizio MariaDB tramite systemctl e ho effettuato l'accesso al database dvwa utilizzando i privilegi di root via socket, necessari sulla distribuzione Kali Linux/Debian:

```
sudo systemctl start mysql  
sudo mysql dvwa
```

Una volta autenticato, ho interrogato la tabella users per estrarre il nome utente e il relativo hash della password:

```
SELECT user, password FROM users;
```

# Esercizio: Password Cracking su DVWA

Argomento: Password Cracking | Recupero delle Password in Chiaro

```
(kali㉿ kali)~# sudo mysql dvwa
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 35
Server version: 11.8.6-MariaDB-6 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [dvwa]> SELECT user, password FROM users;
+-----+-----+
| user | password |
+-----+-----+
| admin | 5f4dcc3b5aa765d61d8327deb882cf99 |
| gordonb | e99a18c428cb38d5f260853678922e03 |
| 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b |
| pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 |
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 |
+-----+-----+
5 rows in set (0,001 sec)
```

Screenshot 1: output della query SQL sul database DVWA.

## 3. Hash MD5 Estratti

La query ha restituito 5 record. Ho verificato che gli hash fossero di tipo MD5 controllando la lunghezza caratteristica di 32 caratteri esadecimale. Nella tabella seguente riporto i valori estratti:

| Utente  | Hash MD5                         |
|---------|----------------------------------|
| admin   | 5f4dcc3b5aa765d61d8327deb882cf99 |
| gordonb | e99a18c428cb38d5f260853678922e03 |
| 1337    | 8d3533d75ae2c3966d7e0d4fcc69216b |
| pablo   | 0d107d09f5bbe40cade3de5c71e9e9b7 |
| smithy  | 5f4dcc3b5aa765d61d8327deb882cf99 |

Ho notato che admin e smithy condividono lo stesso hash: ciò indica che utilizzano la stessa password. John the Ripper ha quindi caricato soltanto 4 hash distinti.

## 4. Esecuzione del Cracking con John the Ripper

# Esercizio: Password Cracking su DVWA

Argomento: Password Cracking | Recupero delle Password in Chiaro

Ho creato un file di input nel formato user:hash richiesto da John e ho avviato un attacco a dizionario usando la wordlist rockyou.txt, specificando il formato Raw-MD5 (hash senza salt):

```
cat > dvwa_hashes.txt << EOF
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
EOF

john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt dvwa_hashes.txt
```

# Esercizio: Password Cracking su DVWA

Argomento: Password Cracking | Recupero delle Password in Chiaro

```
(kali@kali)~$ cat > dvwa_hashes.txt EOF
admin:5f4dcc3b5aa765d61d8327deb882cf99
heredoc> admin:5f4dcc3b5aa765d61d8327deb882cf99
heredoc> gordonb:e99a18c428cb38d5f260853678922e03
heredoc> 1337:8d3533d75ae2c3966d7e0d4fcc69216b
heredoc> pablo:0d107d09f5bbe40cade3de5c71e9e9b7
heredoc> smithy:5f4dcc3b5aa765d61d8327deb882cf99
heredoc> EOF

(kali@kali)~$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt dvwa_hashes.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
fopen: /usr/share/wordlists/rockyou.txt: No such file or directory

(kali@kali)~$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz

john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt dvwa_hashes.txt
[sudo] password di kali:
Riprova.
[sudo] password di kali:
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (admin)
abc123         (gordonb)
letmein        (pablo)
charley        (1337)
4g 0:00:00:00 DONE (2026-05-14 10:42) 200.0g/s 153600p/s 153600c/s 230400C/s my3kids..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Screenshot 2: output di John the Ripper con le password recuperate.

# Esercizio: Password Cracking su DVWA

Argomento: Password Cracking | Recupero delle Password in Chiaro

## 5. Risultati del Cracking

John the Ripper ha completato la sessione in meno di un secondo, recuperando tutte e 4 le password distinte. Di seguito il riepilogo completo:

| Utente  | Hash MD5                         | Password in Chiaro |
|---------|----------------------------------|--------------------|
| admin   | 5f4dcc3b5aa765d61d8327deb882cf99 | password           |
| gordonb | e99a18c428cb38d5f260853678922e03 | abc123             |
| 1337    | 8d3533d75ae2c3966d7e0d4fcc69216b | charley            |
| pablo   | 0d107d09f5bbe40cade3de5c71e9e9b7 | letmein            |
| smithy  | 5f4dcc3b5aa765d61d8327deb882cf99 | password           |

## 6. Considerazioni Finali

Dall'esercizio ho tratto le seguenti osservazioni in ambito di sicurezza:

- Hash senza salt: l'utilizzo di MD5 puro senza salt rende gli hash vulnerabili non solo ad attacchi a dizionario, ma anche a rainbow table precompute. Una stessa password produce sempre lo stesso hash, come dimostrato da admin e smithy.
- Password deboli: tutte le password erano presenti nella wordlist rockyou.txt, una delle più comuni in ambito offensivo. Il cracking si è concluso in meno di un secondo con velocità pari a circa 200.000 hash/s.
- Strumenti utilizzati: ho usato John the Ripper con l'opzione --format=raw-md5; in alternativa sarebbe stato possibile ricorrere a Hashcat con il parametro -m 0 per lo stesso tipo di attacco.
- Contromisure: per mitigare questo tipo di attacco sarebbe necessario adottare funzioni di hashing robuste come bcrypt o Argon2, che includono salt automatico e parametri di costo configurabili.